Aprendizagem Aplicada à Segurança

Class 5: Anomaly Detection I, statistics, neighbours, clusters and classifiers

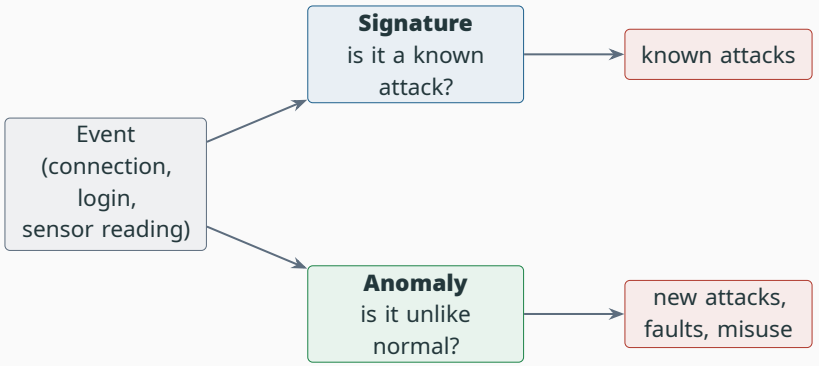
Mário Antunes

October 16, 2026

Universidade de Aveiro

Signatures know the past, anomalies look for the rest

- An **event** is one observation that the detector judges: a network connection, a login, a sensor reading.
- A **signature** (misuse) detector matches known attacks: precise, but blind to anything new.
- An **anomaly** detector models *normal* behaviour and alarms on departures from it.



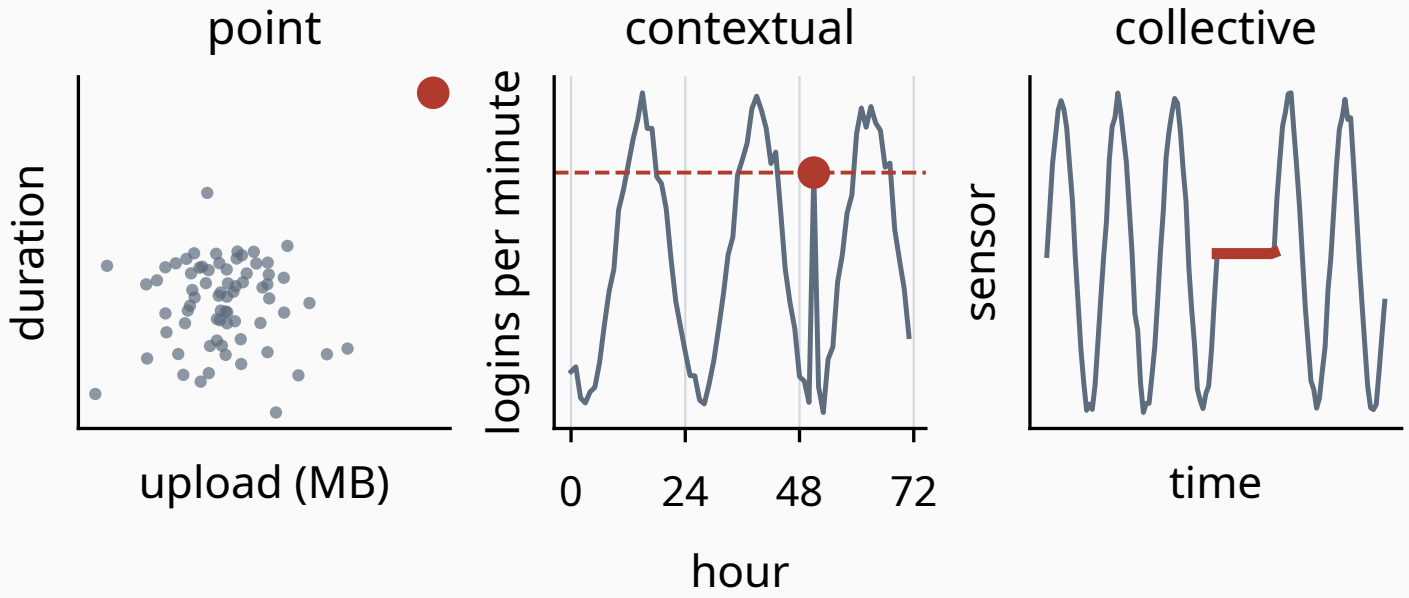
- The price: rare but legitimate events are false alarms.

Terminology: the words of this class

Term	Meaning	Symbol	Example
normal	behaviour seen in the training data	X	ordinary sessions of one host
anomaly	an event unlike normal; rare, not always malicious		a 2 GB upload
score	number, higher = more unusual	$s(\mathbf{x})$	distance from normal
threshold	alarm when the score exceeds it	t	$t = 9.21$
TPR, FPR	share of attacks, of normal events, that raise an alarm	TPR, FPR	0.95, 0.01
base rate	share of attacks among all events	b	1 in 10,000

Three kinds of anomaly

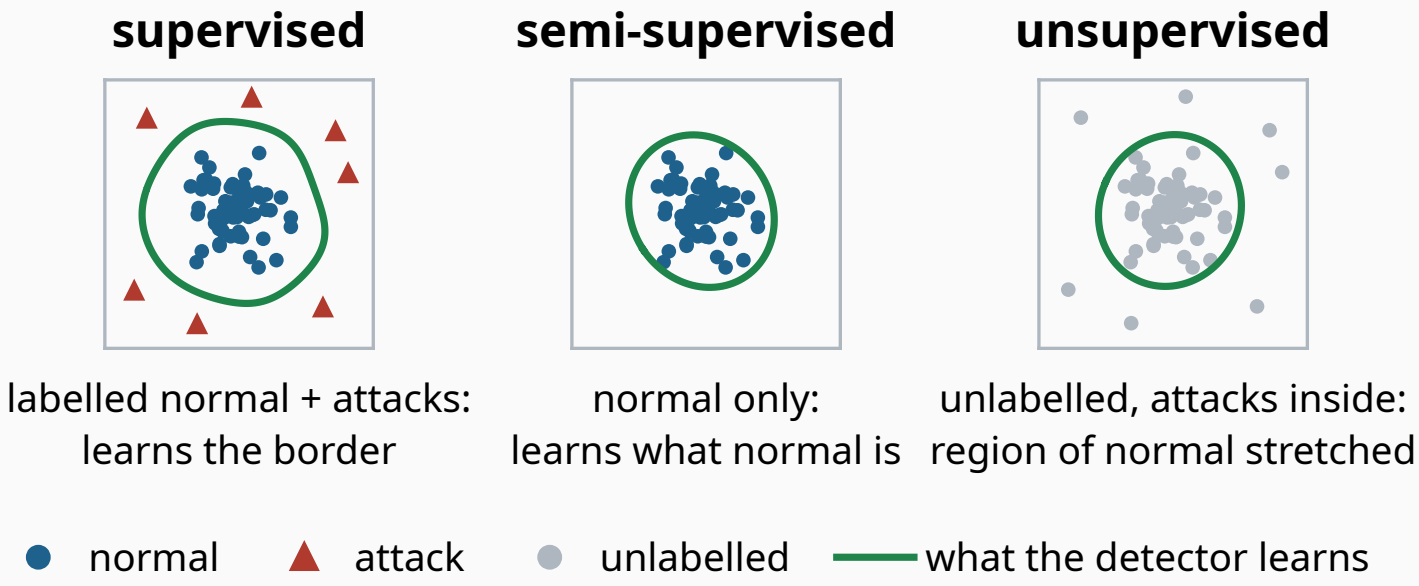
Schematic: unusual alone, in its context, or as a group.
Today: point anomalies (Chandola et al. 2009).



- **Point:** one event far from the rest (a 2 GB upload).
- **Contextual:** a normal value at the wrong time.
- **Collective:** each value ordinary, the pattern is not.

Three settings, by what the training data holds

Schematic: the same events, different labels (Sommer and Paxson 2010).



- **Supervised:** normal + labelled attacks.
- **Semi-supervised (novelty):** normal only.
- **Unsupervised:** unlabelled, attacks inside.

Families of detectors: the map of this class

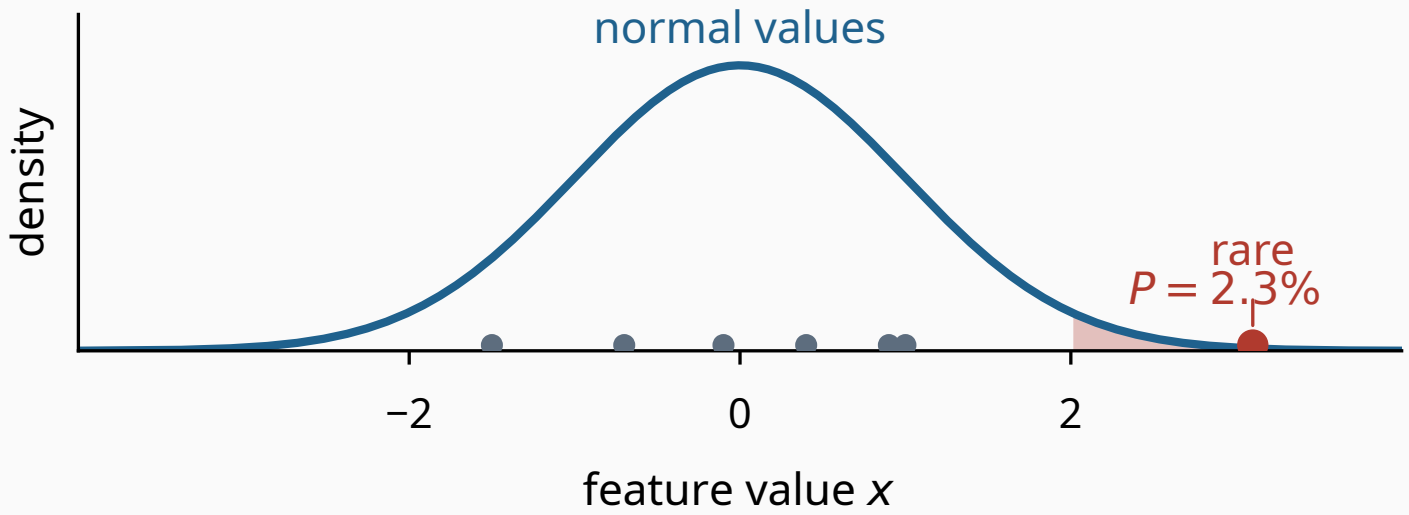
Family	Normal is…	Methods
distribution-based	a probability distribution	z-score, Mahalanobis distance, Gaussian mixture
distance and density	a dense region	kNN distance, LOF
isolation	hard to separate by cuts	Isolation Forest
boundary	inside a learned frontier	one-class SVM
reconstruction	close to a subspace or to a few parts	PCA, ICA, NMF (autoencoders: class 03_02)
clusters	close to a profile	k-means, DBSCAN
supervised	the side of the labelled normal	logistic regression, random forest

Notation

Symbol	Meaning	Shape	Example 1
$\mathbf{x}$	one event as a feature vector	d	$(2, 2)$
X	the normal training rows	$n \times d$	500 sessions
μ	mean of the normal rows	d	$(0, 0)$
σ_j	standard deviation of feature j	scalar	1
C	covariance matrix: how features vary together	$d \times d$	$\begin{pmatrix} 1 & 0.9 \\ 0.9 & 1 \end{pmatrix}$
$s(\mathbf{x}),\ t,\ \alpha$	score, threshold, accepted false-alarm rate	scalar	$t = 9.21$ at $\alpha = 0.01$

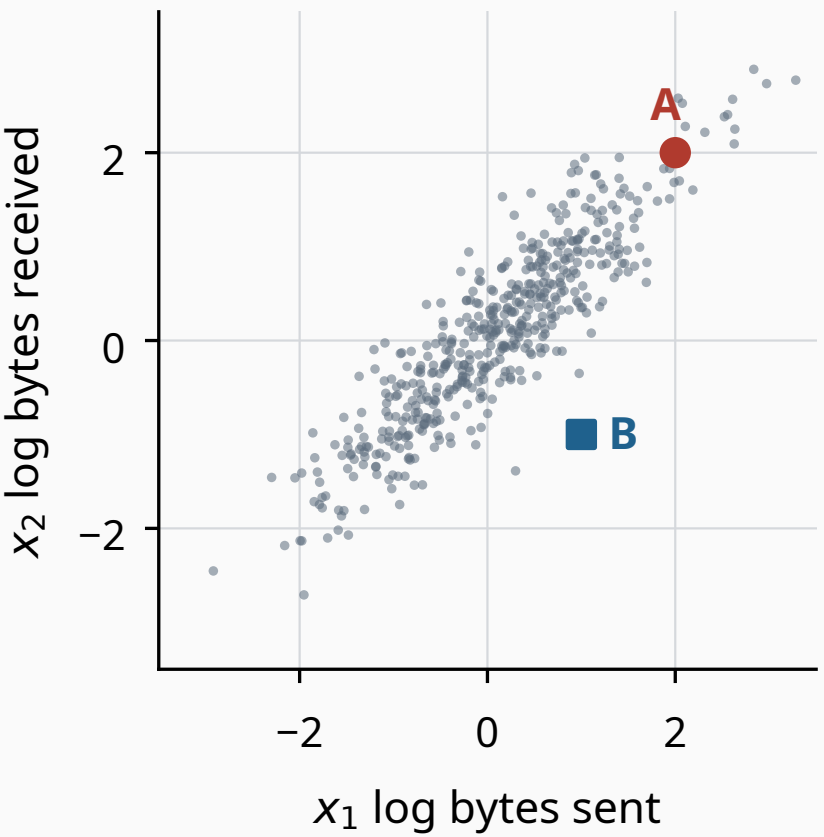
Model normal with a distribution

- **Distribution-based detection** fits a distribution to the normal rows; the score is how unlikely an event is.
- One feature: the **z-score** $z = (x - \mu)/\sigma$, standard deviations from the mean.



- A rare value sits in the tail: $|z| > 2$ holds for 4.6% of normal events.

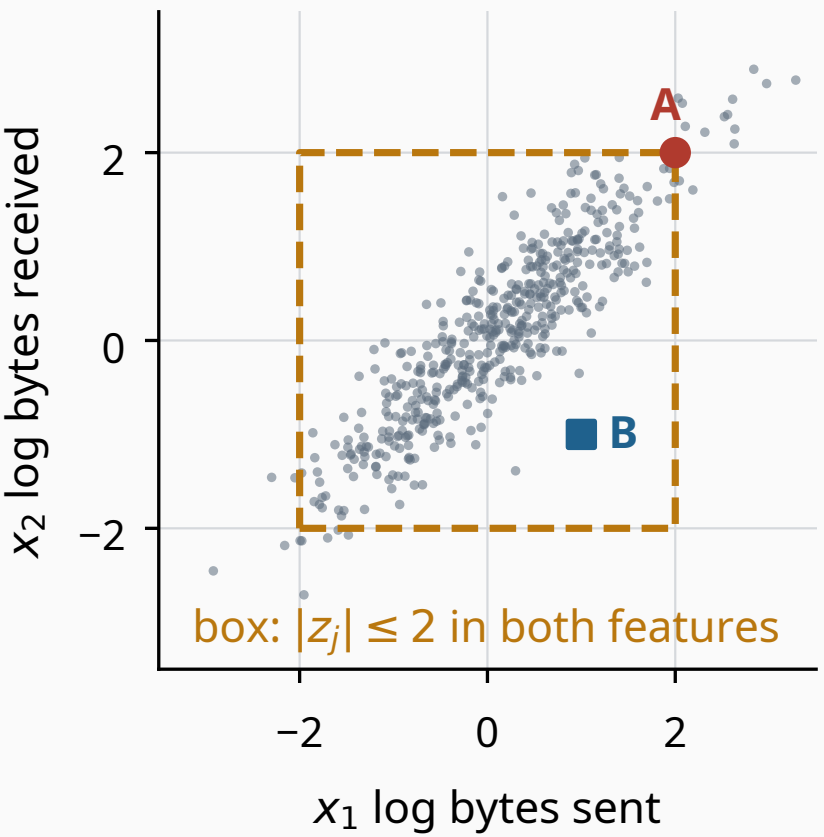
Example 1: one host, two features



- One point = one session: log bytes sent (x_1) and received (x_2), standardised.
- Normal: $\mu = (0, 0)$, unit variances, $\rho = 0.9$.
- **A** $= (2, 2)$: big but consistent.
- **B** $= (1, -1)$: sends a lot, receives little.

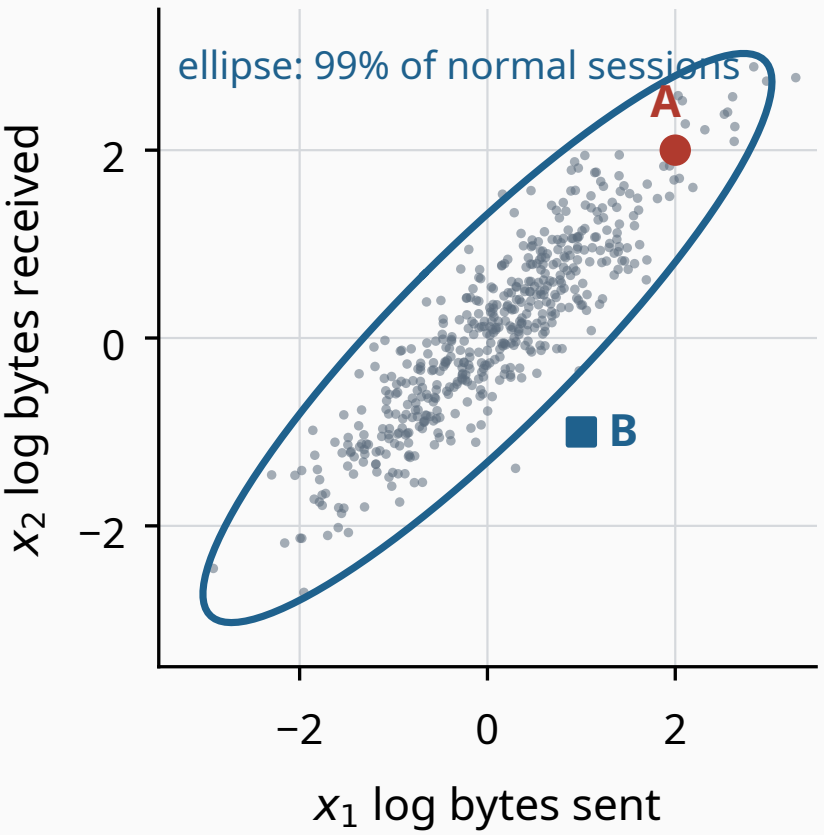
- Which is the anomaly? Notebook 00 rebuilds every number.

The z-score looks at one feature at a time



- Score $s(\mathbf{x}) = \max_j |z_j|$: the box is $|z_j| \le 2$ in both features.
- A: $z = (2, 2)$, score **2**. B: $z = (1, -1)$, score **1**.
- The z-score ranks A above B: B hides inside the box.
- It ignores that the two features move together; B breaks the relation, not a range.

The Mahalanobis distance: the idea



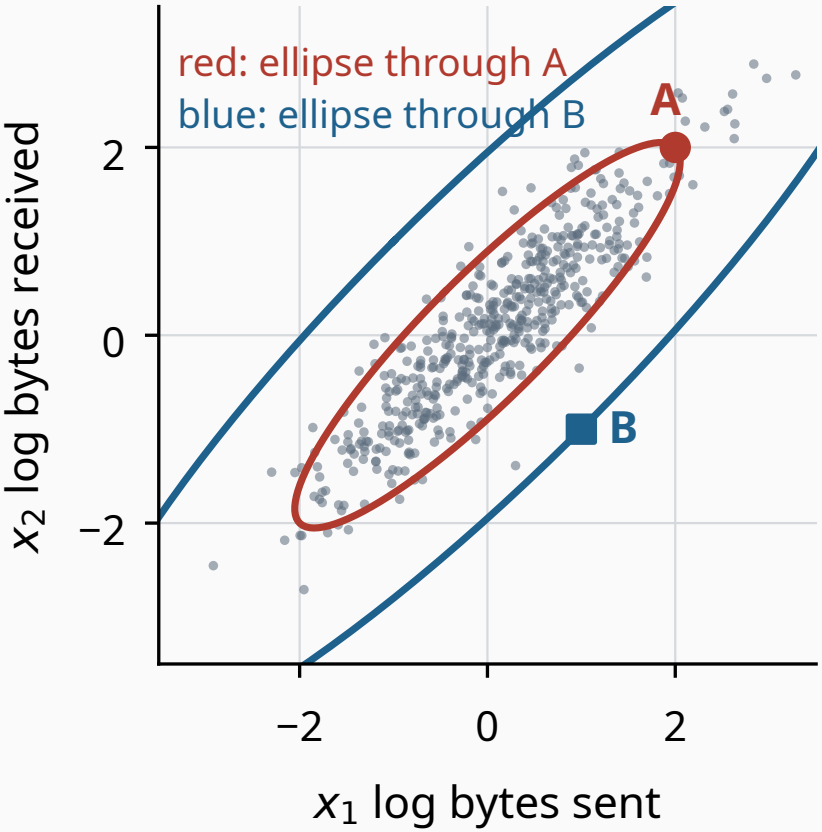
- The **Mahalanobis distance** is the distance from the mean in units of the data's own spread, along its own directions.
- Equal distance = an **ellipse** that follows the cloud, not a box.
- The ellipse $d_M = 3.03$ holds 99% of normal sessions.

The Mahalanobis distance: definition

$$d_M(\mathbf{x})^2 = (\mathbf{x} - \mu)^\top C^{-1} (\mathbf{x} - \mu)$$

- Example 1: $\det C = 1 - 0.81 = 0.19$ and $C^{-1} = \frac{1}{0.19} \begin{pmatrix} 1 & -0.9 \\ -0.9 & 1 \end{pmatrix}$.
- So $d_M^2 = (x_1^2 - 1.8\, x_1 x_2 + x_2^2)/0.19$: the cross term **rewards** features that move together.
- If $C = I$ it is the Euclidean distance; with a diagonal C, $d_M^2 = \sum_j z_j^2$ (the z-scores, combined).

Example 1 by hand: A is normal, B is not

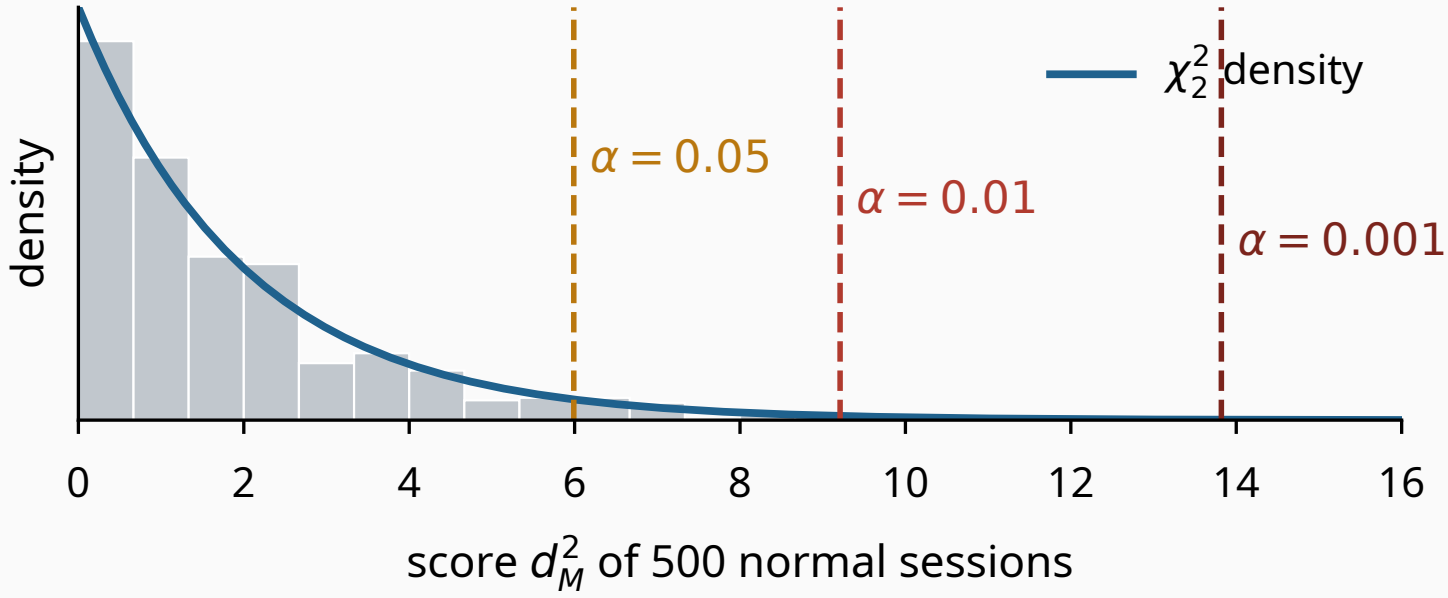


- A: $(4+4-1.8\cdot 4)/0.19 = 4.21.$
- B: $(1+1+1.8)/0.19 = 20.0.$

Point	d_M	$P(\chi^2_2 > d^2_M)$
A	2.05	0.12
B	4.47	0.000045

- The ranking flips: B is a 1-in-22,000 event, A a 1-in-8 event. If normal data are Gaussian, $d^2_M \sim \chi^2_d$ (appendix).

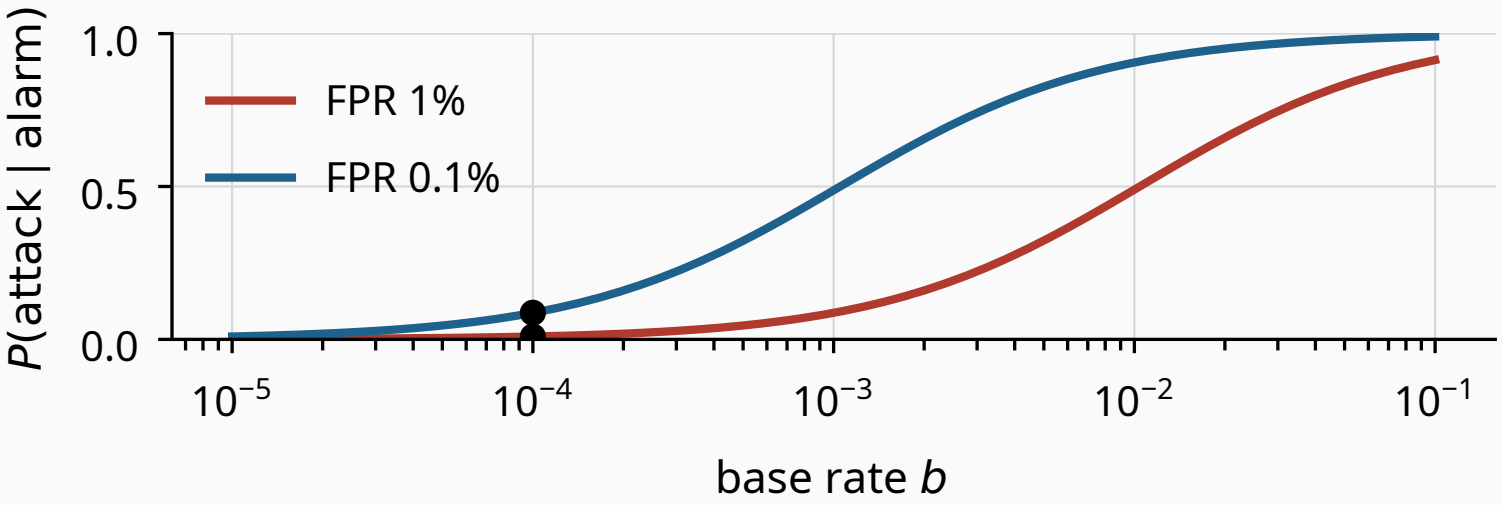
Choosing the threshold without attacks



- Set t on **normal** data: the $(1 - \alpha)$ quantile of the normal scores gives about α false alarms.
- $\alpha = 0.05, 0.01, 0.001$: χ^2_2 gives 5.99, 9.21, 13.82; 500 sessions give 5.97, 8.86, 14.98.
- Small α rests on one or two extreme rows: it needs much more normal data.

The base rate decides what an alarm is worth

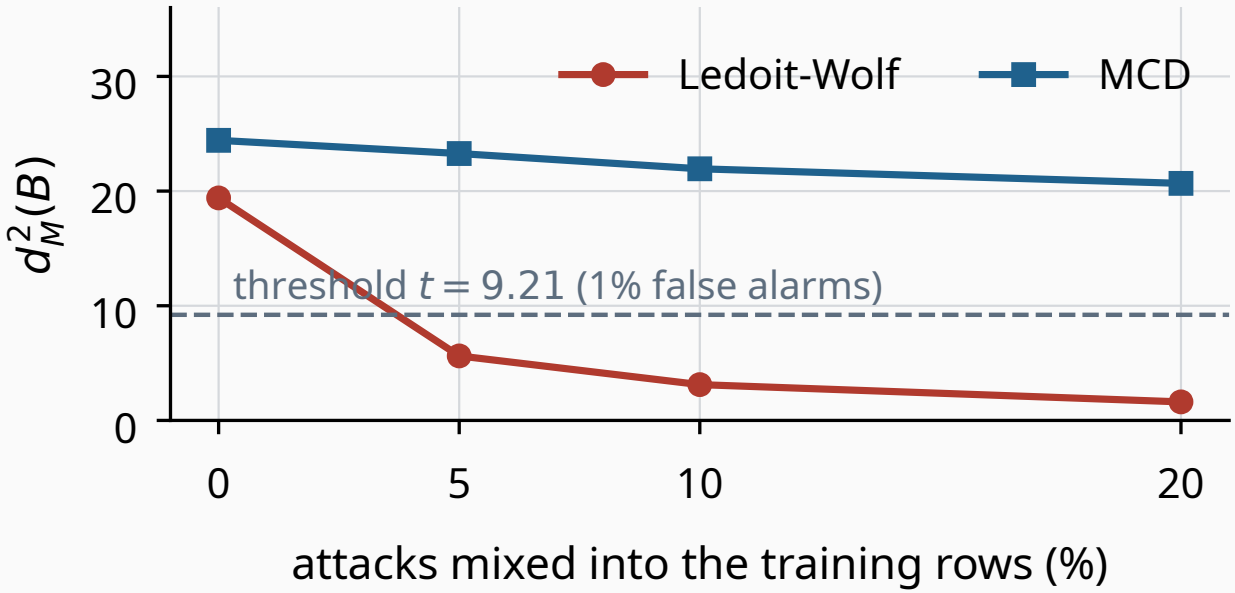
$$P(\text{attack} \mid \text{alarm}) = \frac{\text{TPR} \cdot b}{\text{TPR} \cdot b + \text{FPR} \cdot (1 - b)}$$



- TPR 0.95, $b = 10^{-4}$, FPR 1%: **99 of 100 alarms are false** (Axelsson 2000).

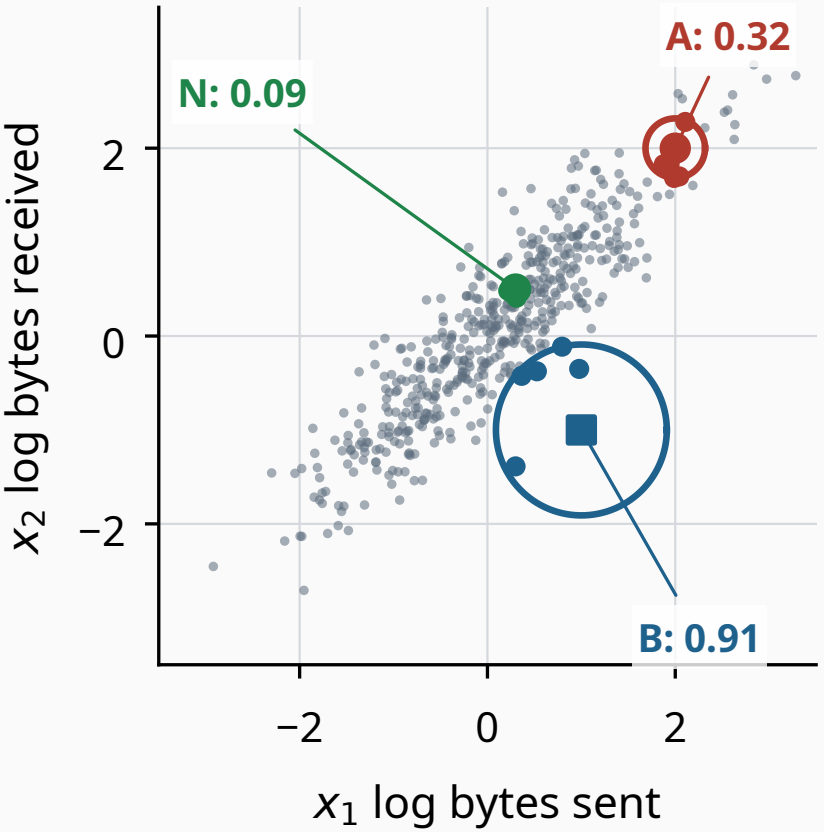
Contamination and robust estimates

- **Contamination:** the training rows already hold attacks (copies of B); the mean and covariance follow them.



- **Ledoit-Wolf** (Ledoit and Wolf 2004) is not robust: 5% copies cut $d_M^2(B)$ from 19.4 to 5.6; **MCD** (Rousseeuw and Van Driessen 1999) keeps 23.3.

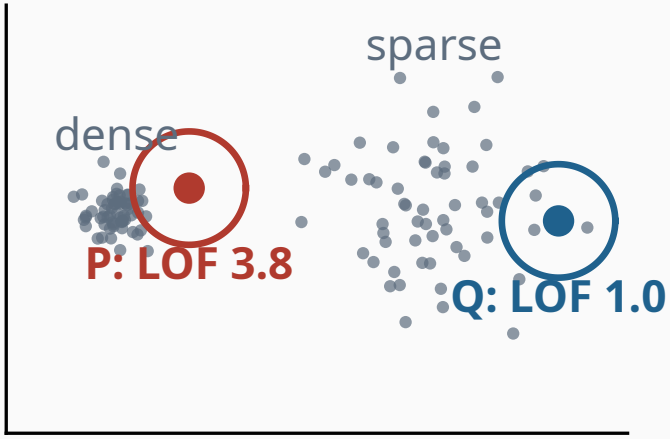
Distance: the kNN score



- $s(\mathbf{x})$ = distance to the k-th nearest normal point ($k = 5$): the radius of each circle.
- N (normal): 0.09. A: 0.32.
- B: 0.91, the largest circle: B sits in a sparse part of the cloud.

Density: the idea of LOF

- The **Local Outlier Factor** (LOF) (Breunig et al. 2000) compares the density around **x** with the density around its neighbours.



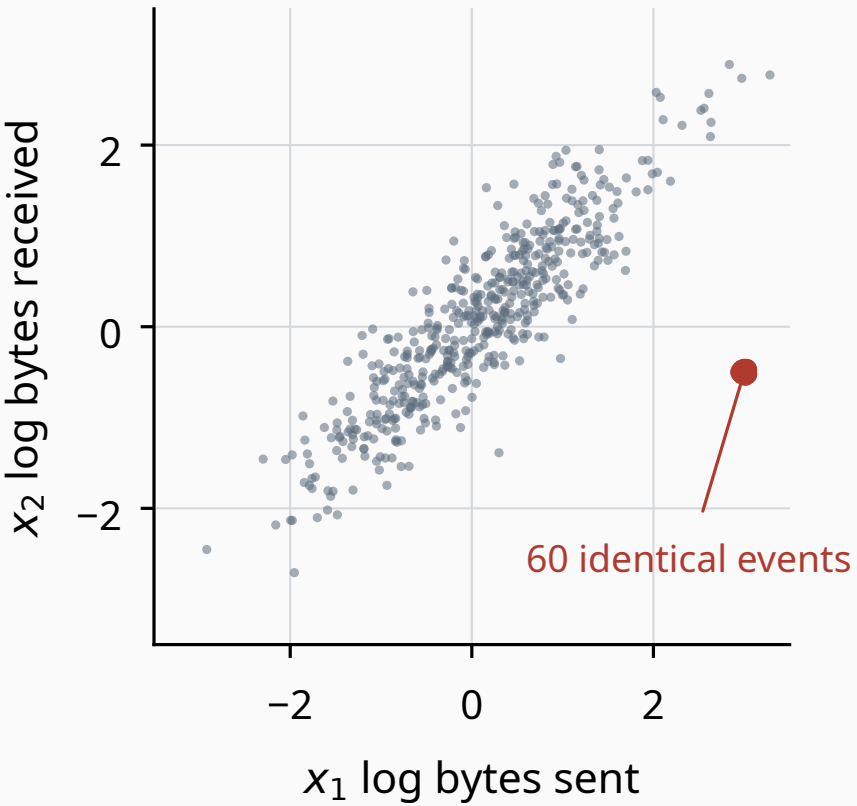
- P and Q have the same kNN distance (0.82); P is far from its dense neighbours: LOF 3.8. Q: 1.05 (≈ 1 is normal).

LOF: definition

$$\mathrm{LOF}_k(\mathbf{x}) = \frac{1}{k} \sum_{\mathbf{o} \in N_k(\mathbf{x})} \frac{\mathrm{lrd}(\mathbf{o})}{\mathrm{lrd}(\mathbf{x})}$$

- $N_k(\mathbf{x})$: the k nearest neighbours. lrd: local reachability density, the inverse of the mean distance to them (appendix).
- A ratio of densities: it adapts to regions of different density, and returns 1 inside any dense cluster.

LOF is blind to a dense attack

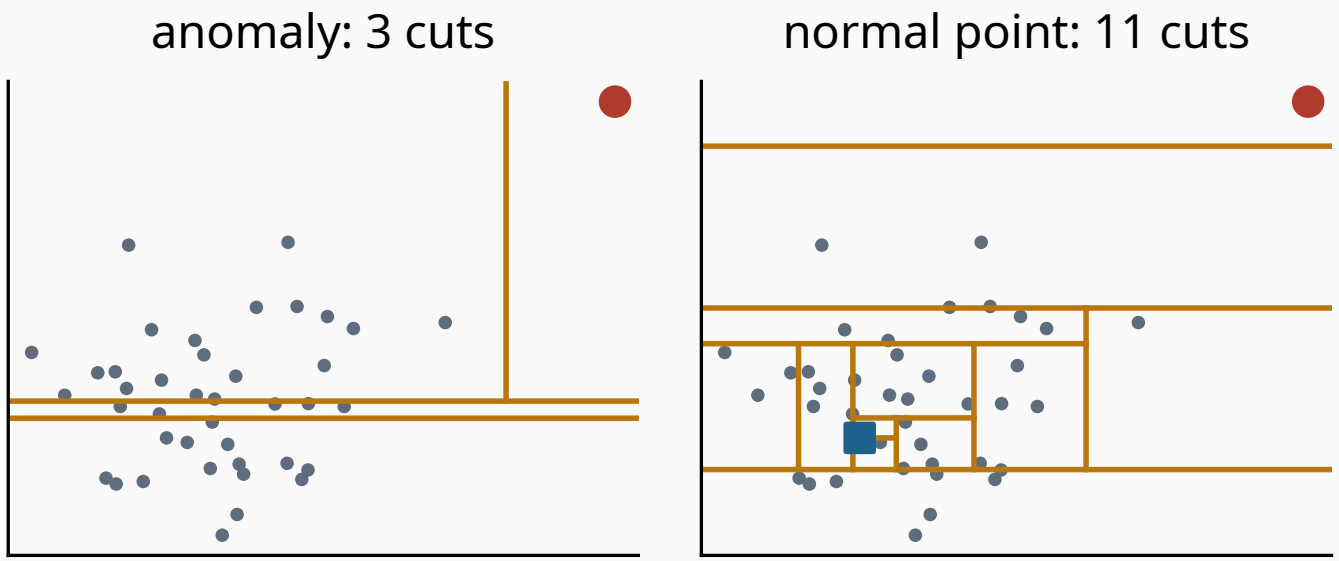


- A flood is many near-identical events: a **dense** cluster (red, 60 points).
- LOF of the flood: 5.66 at test time, **1.07** once it is in the training data: its points are each other's neighbours.
- On KDD99, LOF misses 92% of the DoS rows.

Notebook 00, part D rebuilds these numbers.

Isolation: the idea

- **Isolation Forest** (Liu et al. 2008) cuts a random feature at a random value until the event is alone.
- An anomaly is alone after **few** cuts; an event in a dense region needs many.



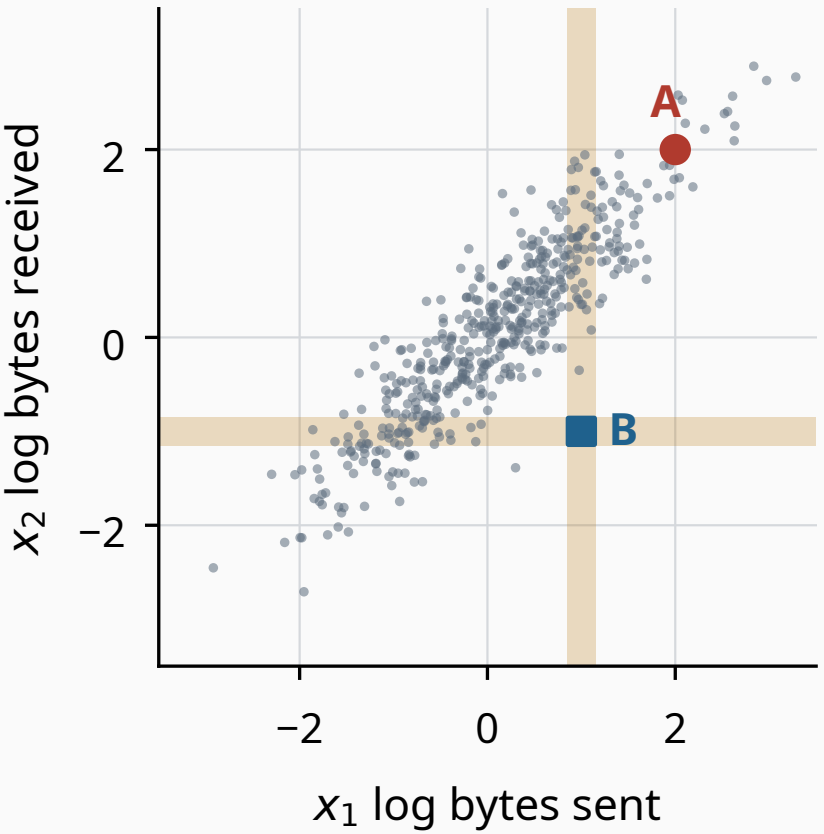
Isolation Forest: definition and score

$$s(\mathbf{x}) = 2^{-E[h(\mathbf{x})]/c(n)}, \qquad c(n) = 2H(n-1) - \frac{2(n-1)}{n}$$

- h: path length (number of cuts); $E[h]$: its mean over the trees; $c(n)$: mean path in a random binary tree of n points; $H(i) \approx \ln i + 0.5772$.
- Trees use subsamples of $n = 256$: $c(256) = 10.25$. Isolated after 4 cuts: $s = 2^{-4/10.25} = 0.76$; after 10.25 cuts: $s = 0.5$.

Isolation Forest: fast, robust, axis-bound

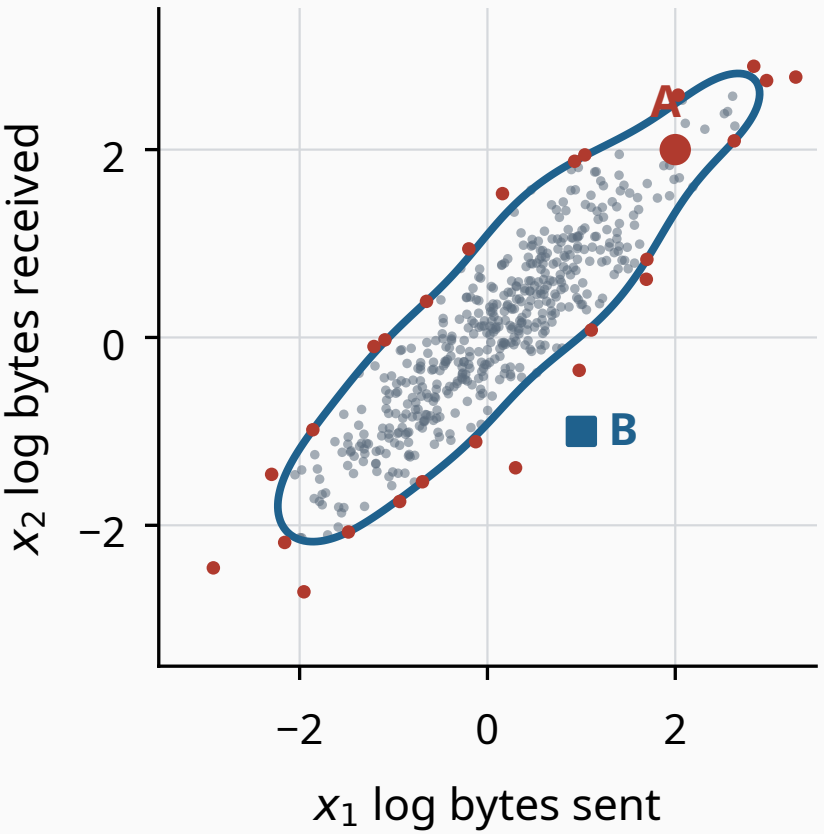
- Linear time; each tree sees 256 random rows: robust to contamination.



- Cuts are **axis-aligned**.
- B is ordinary on each axis: 41 and 39 normal sessions share its x_1 and x_2 (strips), so no cut isolates it.
- Rank of B among 500 normal sessions (0 = above all): Mahalanobis 0, LOF 0, kNN 2, **forest 31**.

A boundary around normal: the one-class SVM

- The **one-class SVM** (Schölkopf et al. 2001) learns a frontier that encloses most of the normal rows.



- RBF kernel, $\nu = 0.05$: 27 of 500 rows (red) fall outside.
- B is far outside, A inside.
- ν bounds the share of rows left outside: the target false-alarm rate.

One-class SVM: definition

- Map the data with a kernel map ϕ; separate it from the **origin** with the widest margin:

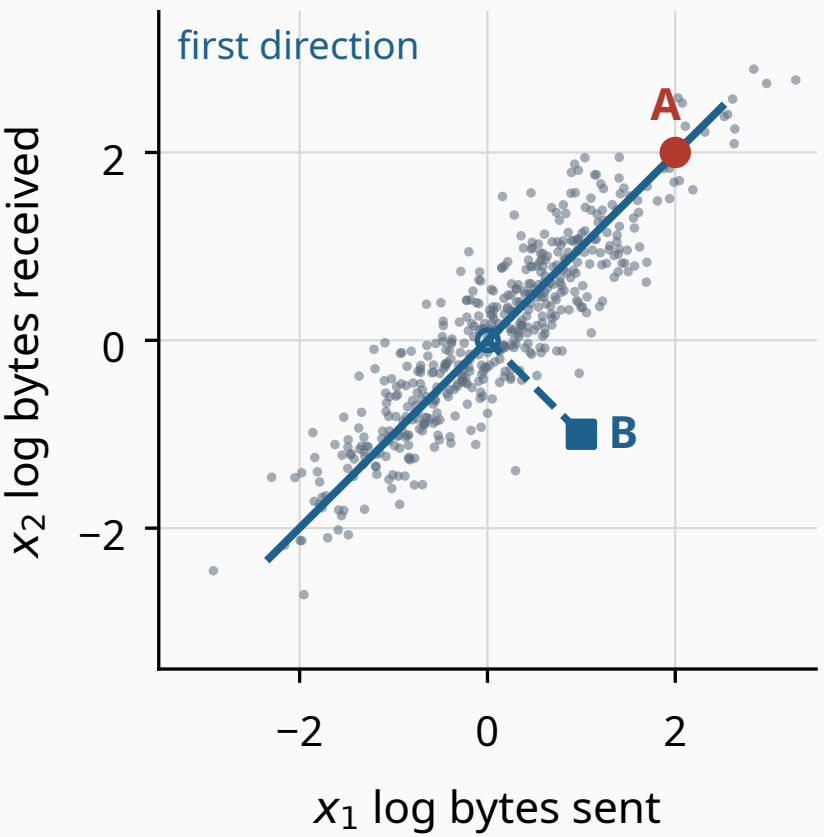
$$\min_{\mathbf{w},\xi,\rho} \ \tfrac{1}{2}\|\mathbf{w}\|^2 + \frac{1}{\nu n}\sum_i \xi_i - \rho$$

$$\text{subject to} \quad \mathbf{w}^\top \phi(\mathbf{x}_i) \geq \rho - \xi_i, \quad \xi_i \geq 0$$

- ξ_i: slack of row i, how far it falls outside. Score: $s(\mathbf{x}) = \rho - \mathbf{w}^\top \phi(\mathbf{x})$, positive outside.
- Training is quadratic in n: we fit 5,000 rows.

A subspace for normal: PCA reconstruction

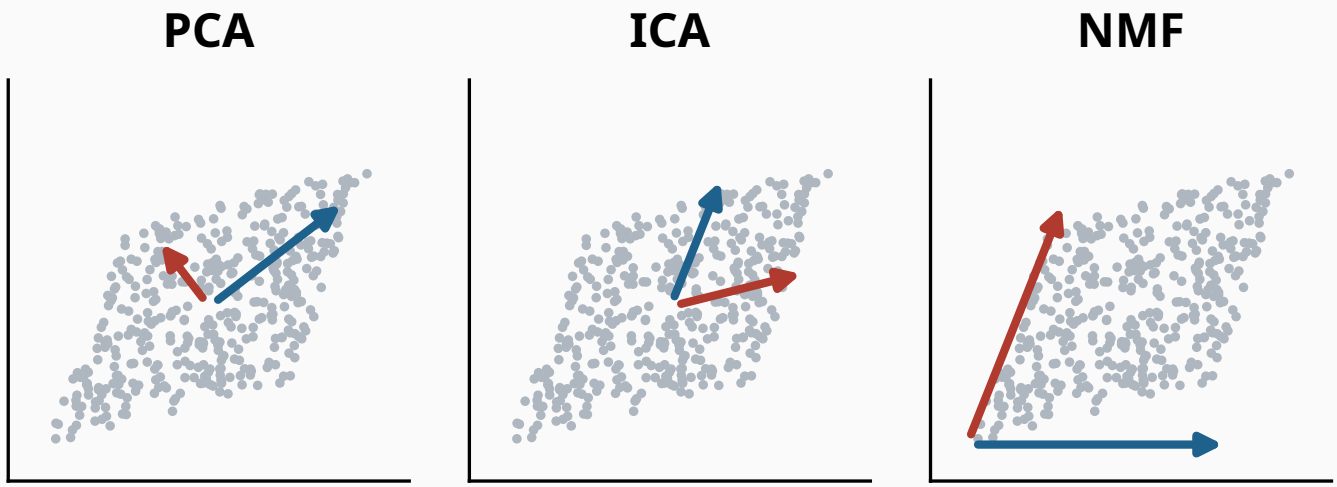
$$s(\mathbf{x}) = \|(\mathbf{x} - \mu) - V_k V_k^\top (\mathbf{x} - \mu)\|^2$$



- V_k ($d \times k$): top k principal directions ($k = 1$, blue line).
- Score = the dashed residual: A 0.0, B 1.99.
- PCA is the linear twin of the autoencoder (class 03_02).

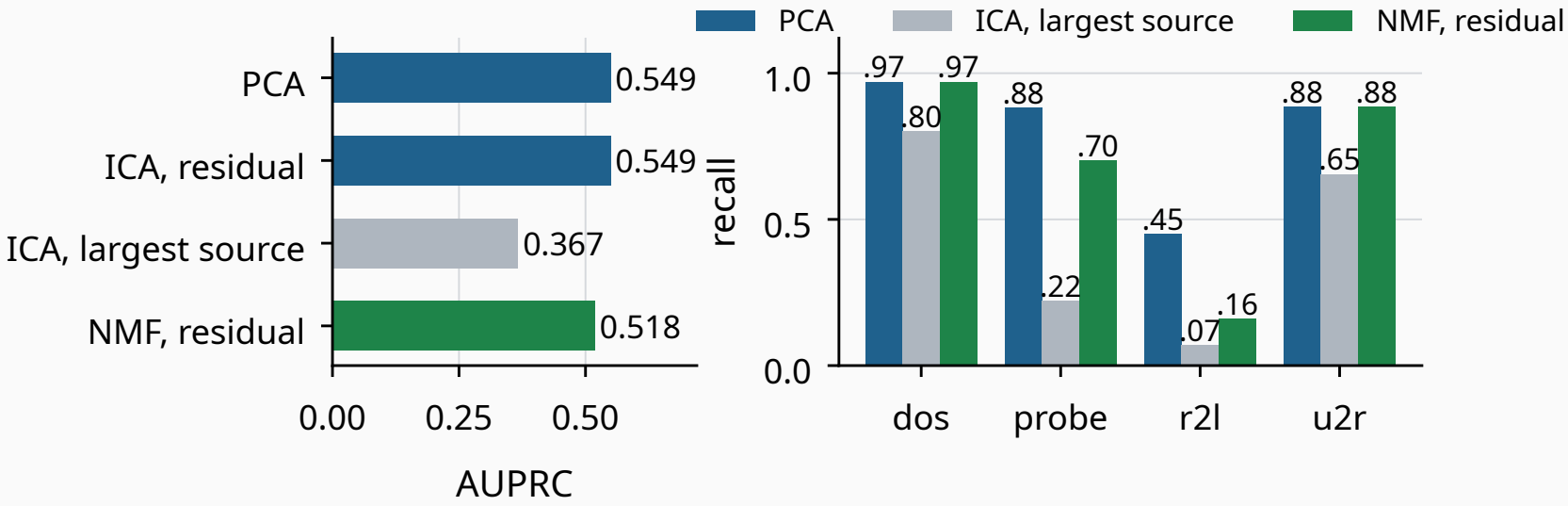
Blind source separation: PCA, ICA and NMF

- **ICA** (independent component analysis (Hyvärinen and Oja 2000)) and **NMF** (non-negative matrix factorisation (Lee and Seung 1999)) join PCA: each event is a mix of a few sources or parts.
- The constraint differs; the score is always the squared residual.



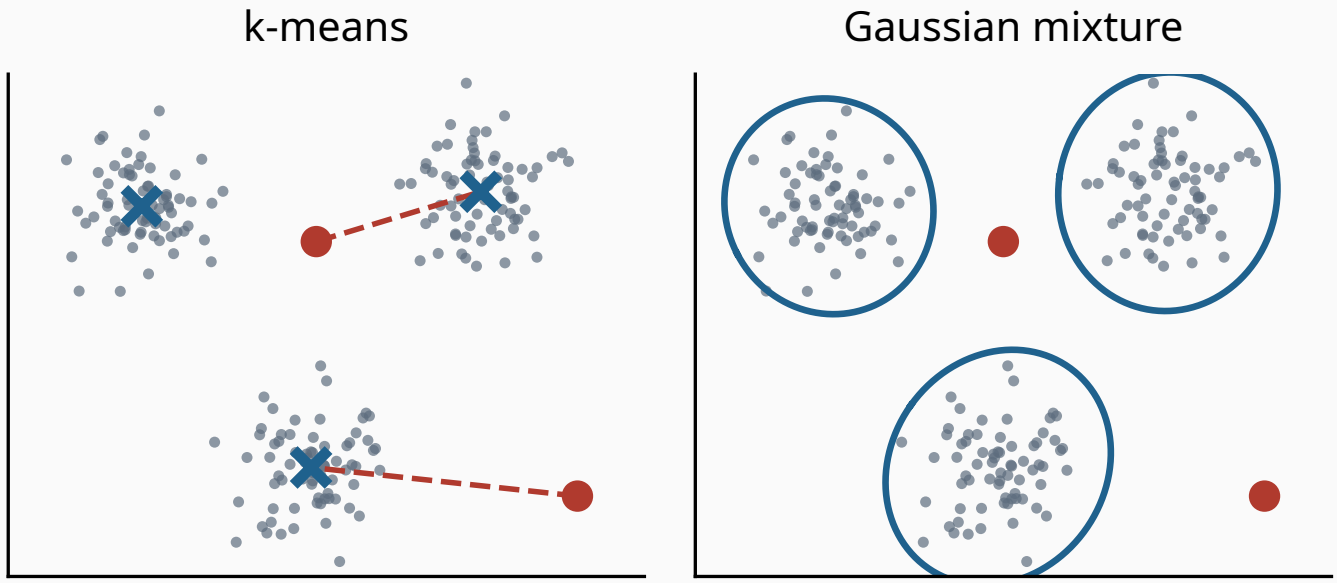
PCA, ICA and NMF on KDD99

Question: does the constraint change what is found?



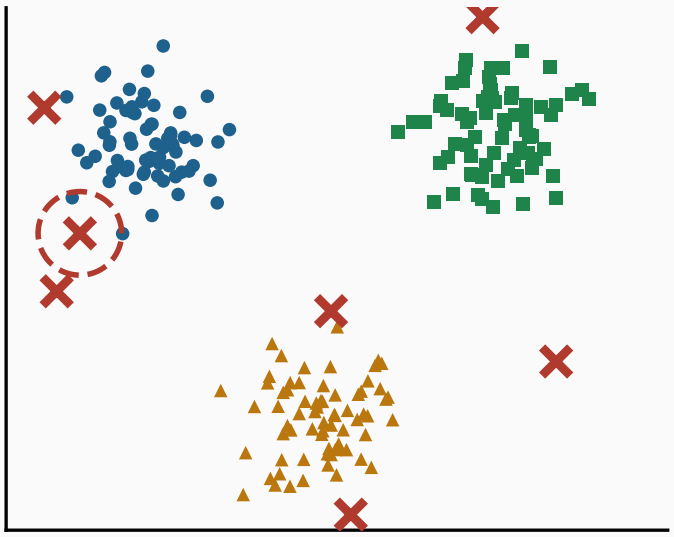
- $k = 41$ (95% of the variance); NMF by `pyNNMF` (HALS). ICA spans PCA's subspace: residual 0.549, largest source 0.367.
- NMF (0.518) misses probe (0.70) and r2l (0.16).

Clusters: k-means and mixtures



- Three profiles (web, mail, DNS). **k-means**: distance to the nearest centre (far point 4.0, between profiles 2.57).
- **Gaussian mixture**: $s = -\log p(\mathbf{x})$, $p = \sum_j \pi_j \mathcal{N}(\mathbf{x}; \mu_j, C_j)$: one Mahalanobis model per profile. Red points: 28.8 and 12.7 (normal: 2.4).

Clusters: DBSCAN



- **DBSCAN** (Ester et al. 1996) marks an event as *noise* (red) when fewer than 6 events lie within $\varepsilon = 0.6$ (dashed circle).
- An anomaly label for free, but no score for a new event.
- Normal traffic is a mixture (web, mail, DNS): clusters fit it better than one Gaussian.

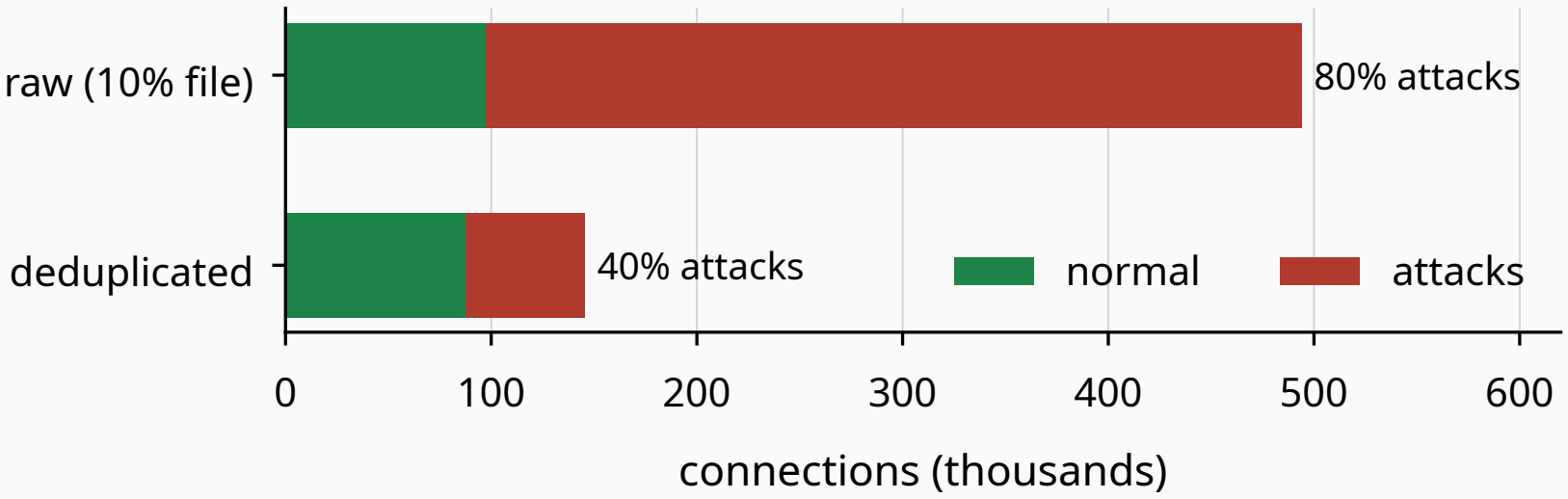
A famous, flawed benchmark

- 41 features per TCP/IP connection from simulated 1998 traffic; 22 attacks in four categories.

Category	What it does	Examples
dos	floods a service	neptune (SYN flood), smurf
probe	scans hosts and ports	satan, ipsweep, nmap
r2l	gets a local account from outside	guess_passwd, warezclient
u2r	escalates to root	buffer_overflow, rootkit

- Known flaws: duplicates, too easy, old traffic (Tavallaee et al. 2009). We use it *because* its flaws teach the protocol.

Lesson 1: remove the duplicates



- 70.5% of the rows are copies, almost all of two floods (smurf, neptune): on the raw file a detector is graded on recognising them.
- Deduplicated: 87,831 normal, 54,572 dos, 2,131 probe, 999 r2l, 52 u2r. Even so, 40% attacks is far from any real network.

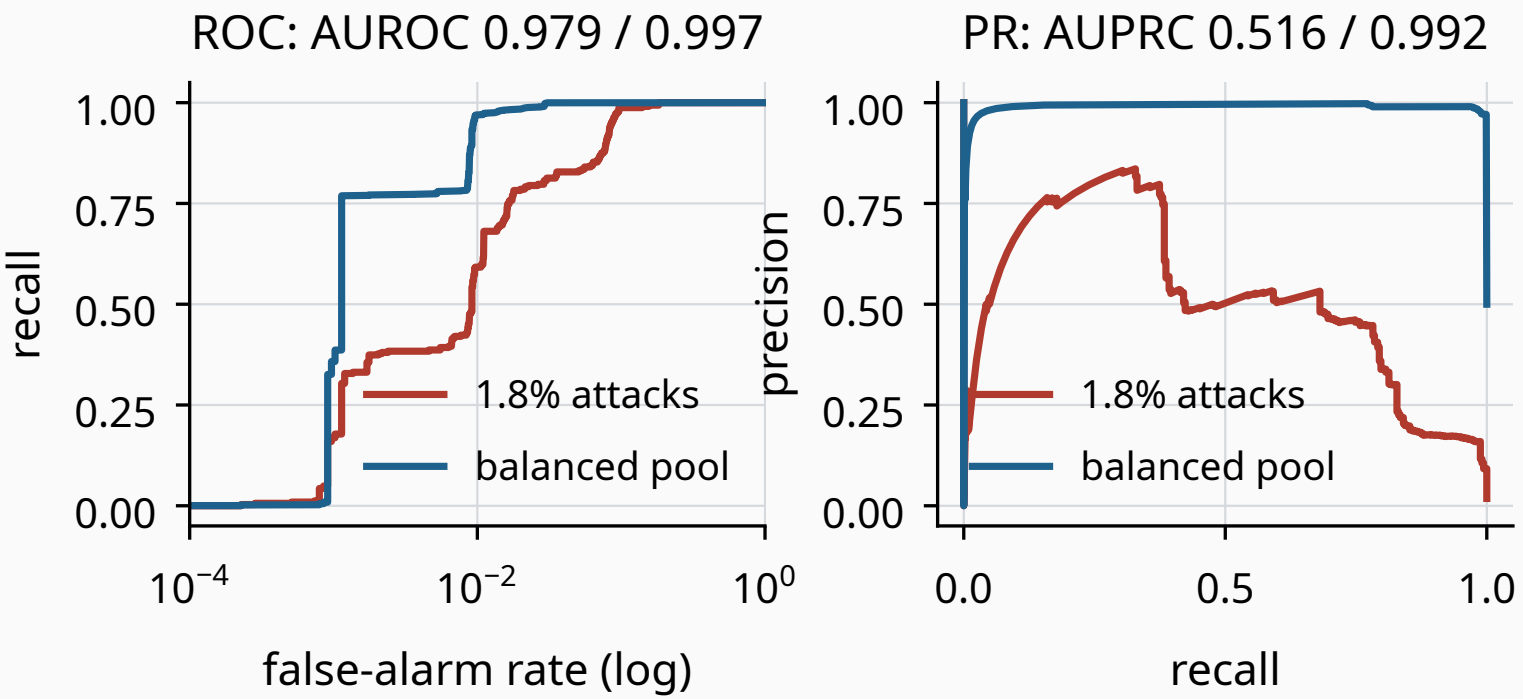
Terminology: the metrics

Metric	Question it answers	Mahalanobis, test set
recall (TPR)	which share of the attacks raises an alarm?	0.681
false-alarm rate (FPR)	which share of normal events raises an alarm?	0.010
precision	which share of the alarms is an attack?	0.516
AUROC	does a random attack outscore a random normal event?	0.979
AUPRC	precision averaged over all recalls; a random score gets b	0.516
recall per category	recall inside dos, probe, r2l, u2r	next frames

The protocol: novelty detection at a realistic base rate

- Features: $\log(1+x)$ for bytes and counts, one-hot for protocol, service, flag (71 features), z-scaling fitted on normal training rows.
- Normal rows 60 / 20 / 20: **train** (52,698), **validation** (17,566), **test**; attacks never in training.
- Test attacks: 100 per category (u2r: 26), **1.8%** of the test set; the rest form a labelled **pool**.
- Threshold: 99% quantile of the validation scores (1% false alarms).

Lesson 2: ROC hides the base rate, precision does not



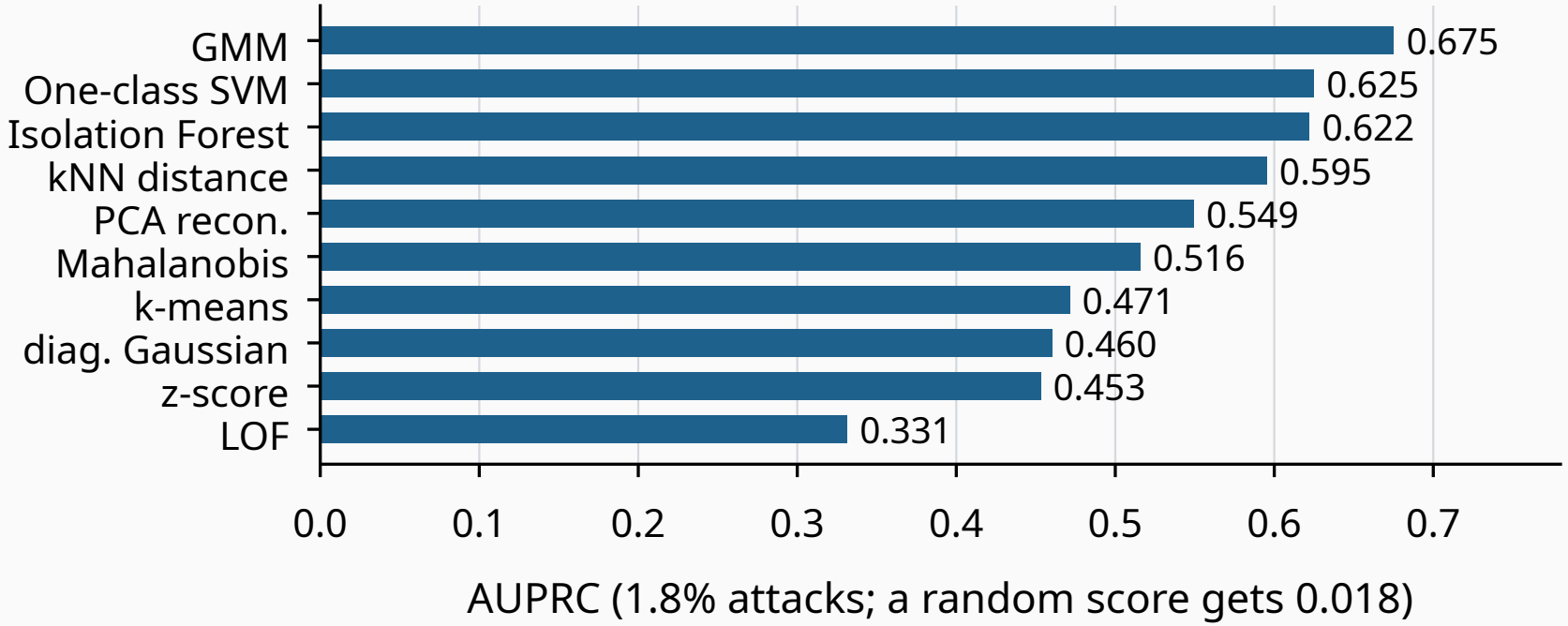
- Same scores, two test sets: 1.8% attacks, and a balanced pool.
- AUROC hardly moves; precision collapses when attacks are rare.

DEMO 02

`notebooks/02-anomaly/notebook_02.ipynb`

Ten detectors, one protocol

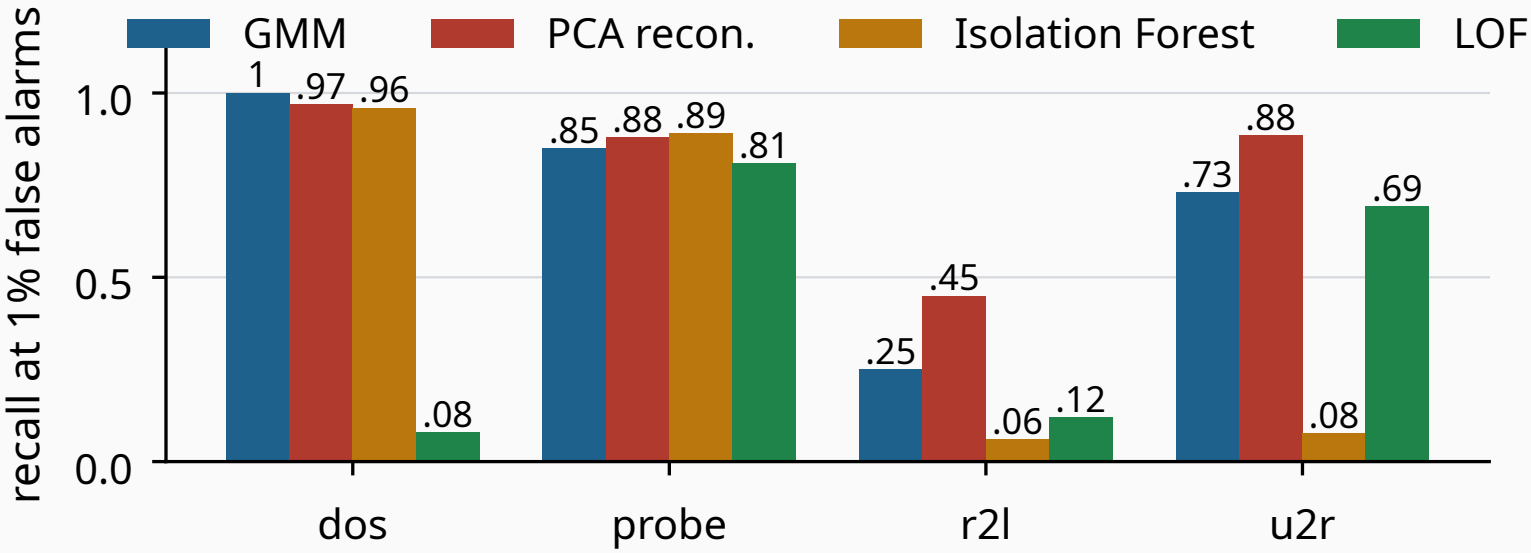
Question: which detector finds the most attacks?



- Longer = better. AUROC is 0.94-0.99 for all ten, AUPRC 0.33-0.68.
- The mixture wins; the z-score is in the lower half.

Recall per category: one average hides the blind spots

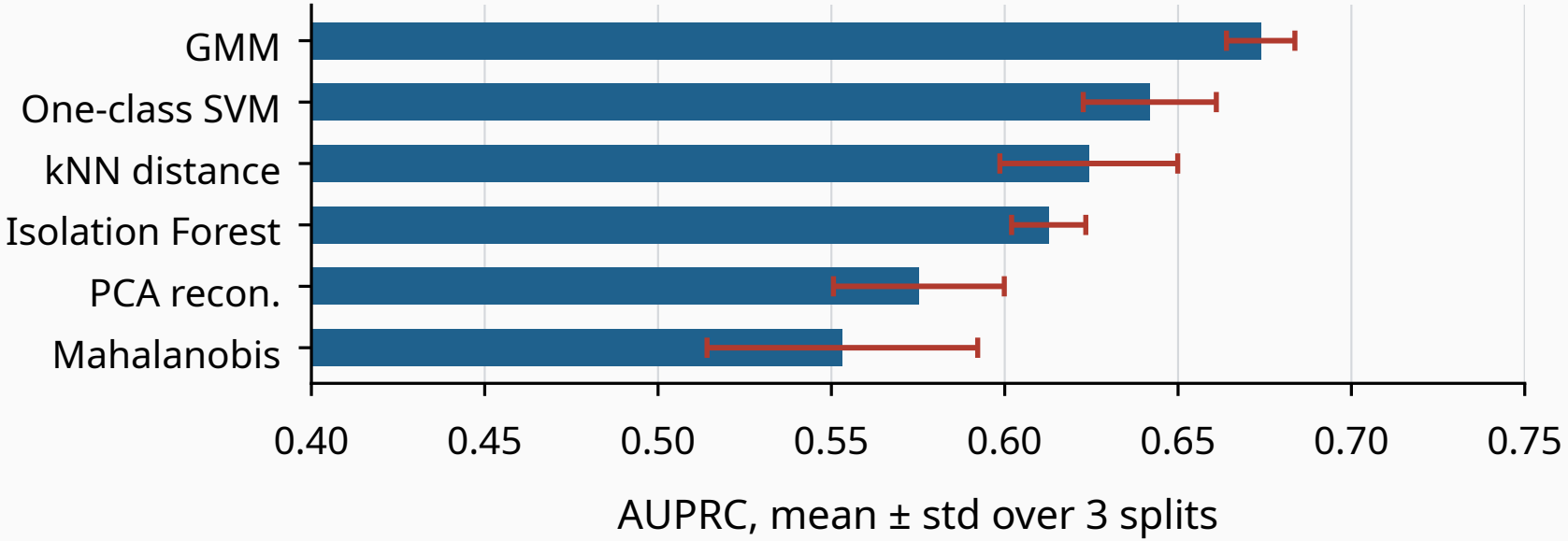
Question: which attack kinds does each detector miss?



- dos and probe are easy, except LOF on the floods (0.08).
- **r2l** (password guessing) *is* a normal-looking login: hard for all.

Is the ranking stable? Three splits

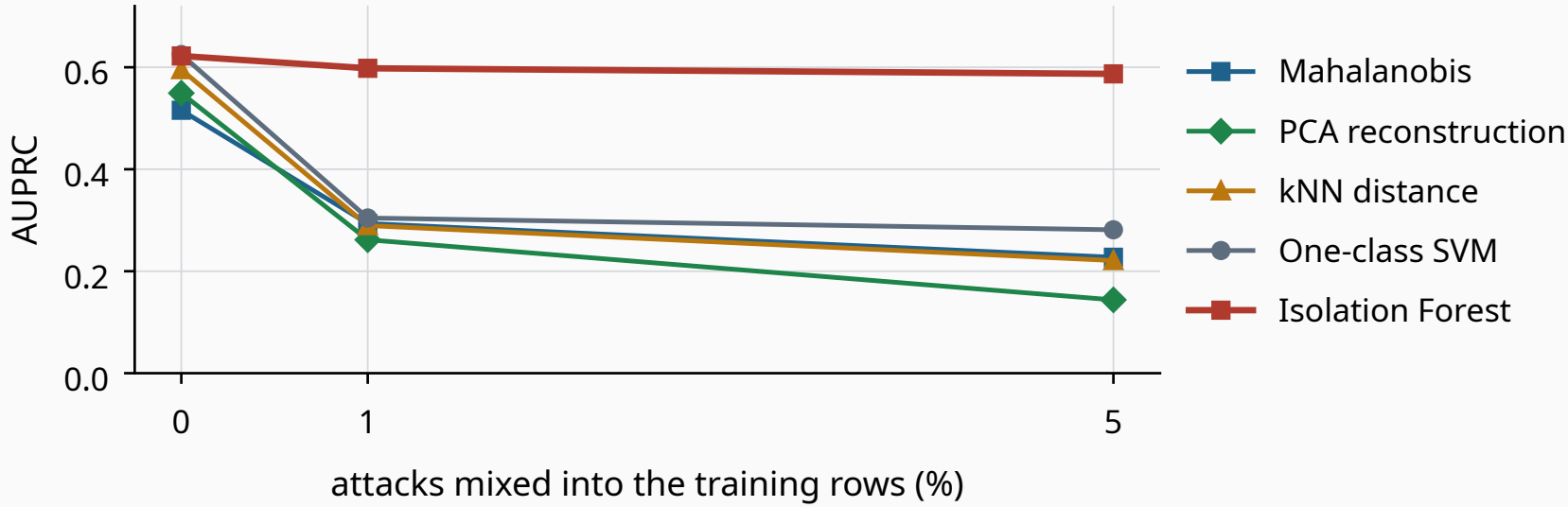
Question: does the order survive another random split?



- Mean over three splits, red whisker = one standard deviation.
- Gaps of 2-3 points are inside it: **never rank on one split** (Han et al. 2022).

Unsupervised setting: attacks in the training data

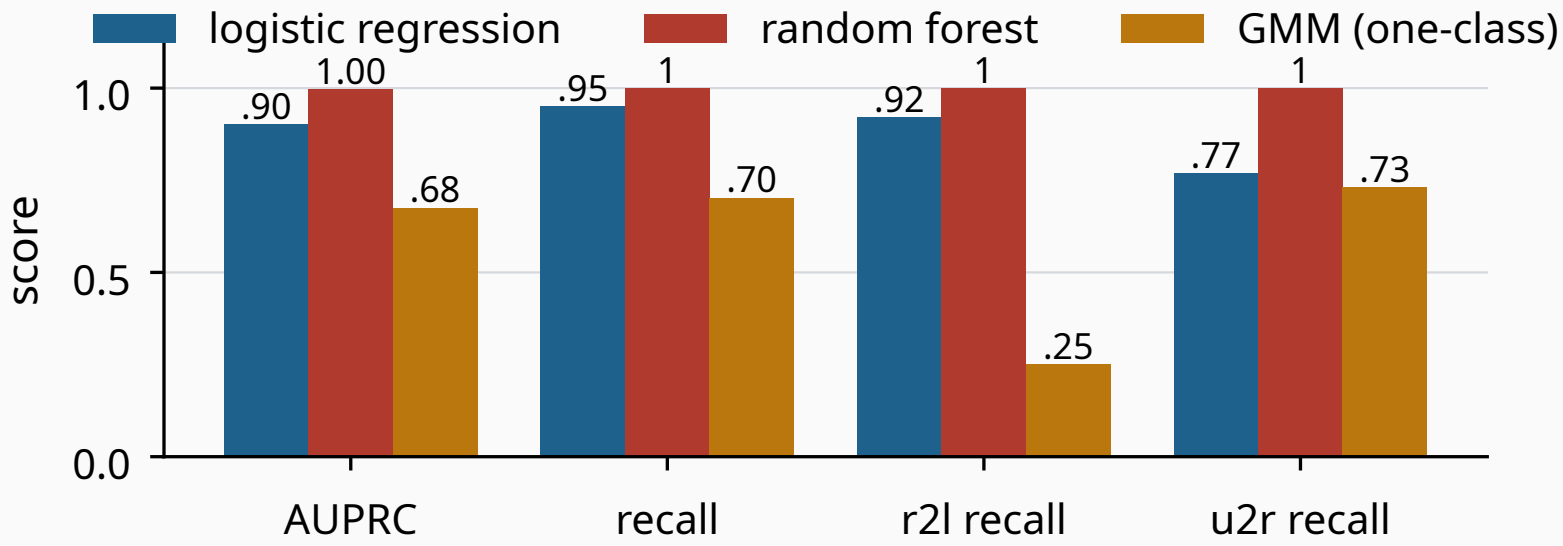
Question: what if the training rows already hold attacks?



- One line per detector, from clean rows to 1% and 5% attacks (mostly DoS).
- 1% halves most detectors; the forest barely moves (each tree sees 256 random rows).

With labels for every attack kind, a classifier wins

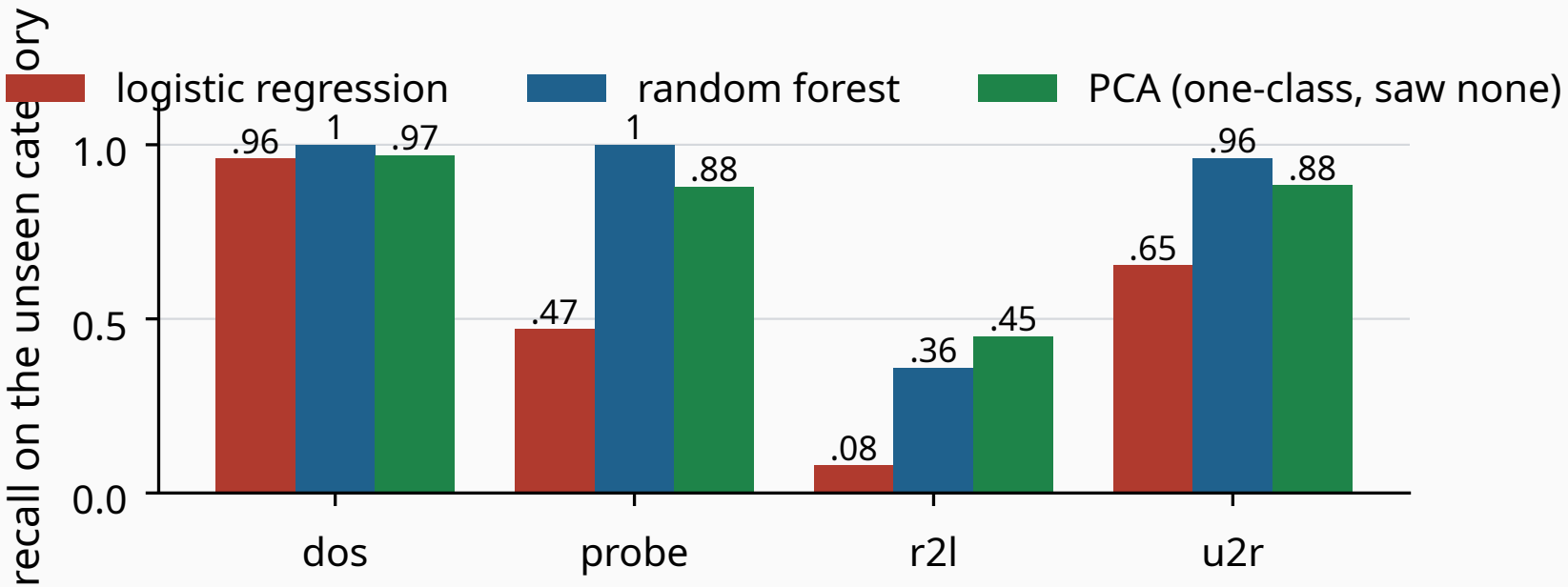
Question: how much do labelled attacks help?



- Forest AUPRC 0.998 against 0.675 for the GMM: KDD99 is “too easy” (Tavallaee et al. 2009).
- The catch: the classifier has seen *these* attacks.

Leave one category out: the new attack

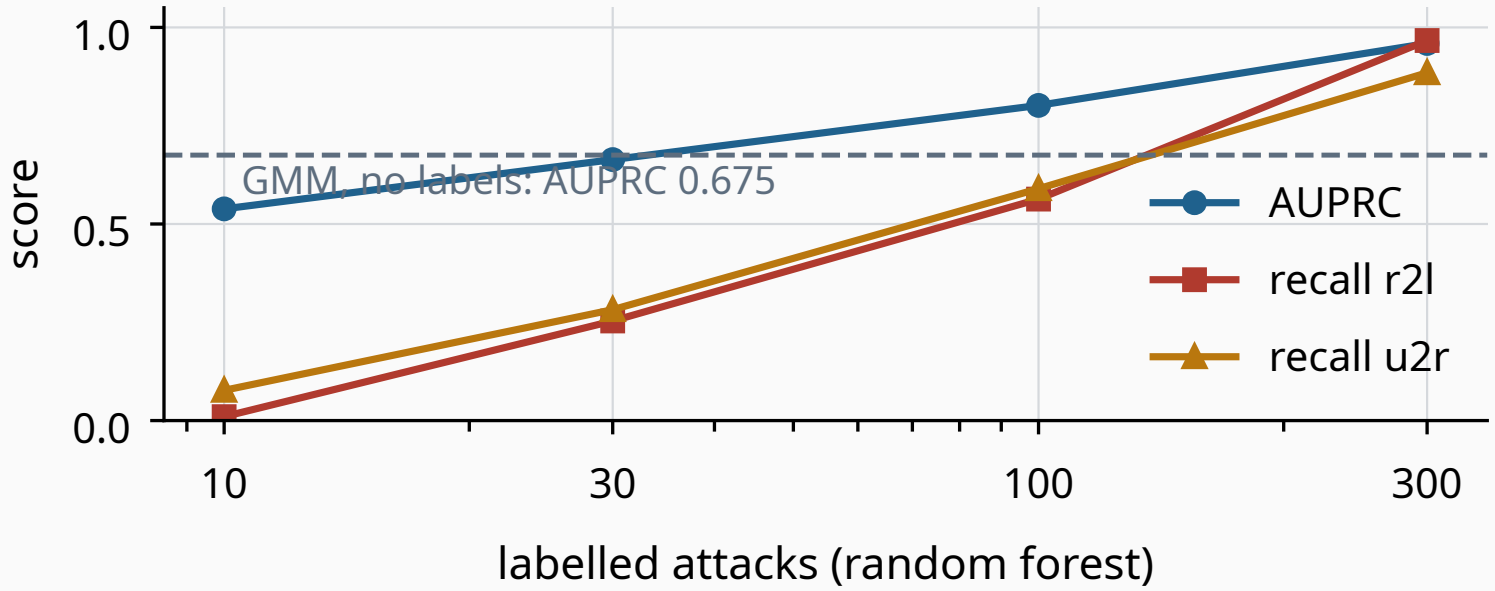
Question: how does a classifier do on an attack it never saw?



- Retrain without one category, measure recall on it.
- r2l falls on the normal side (forest 0.36); one-class PCA: 0.45.

Few labels: the classifier needs a few hundred

Question: how many labels beat the one-class detector?



- Forest, labels drawn from the pool (95% DoS), mean of 3: it passes the GMM between 30 and 100 labels; r2l and u2r need about 300 (Ruff et al. 2020).

Labs and practice guide

Notebook	Content
00	Example 1: z-score vs Mahalanobis, thresholds, base rate, MCD, kNN / LOF / forest
01	KDD99: duplicates, features, protocol, ROC vs precision-recall
02	ten detectors, per category, three splits, contamination, explanations
03	classifiers vs one-class: all labels, leave one category out, few labels

- **Guide** `practice/anomaly/guide_03_01`: z-score and Mahalanobis by hand, threshold rule, AUPRC, the detector zoo, leave one category out.

Take-aways

- Model **normal**, score the departure, set the threshold on **normal** data; the **base rate** decides what an alarm is worth.
- Six families: distribution-based, distance and density, isolation, boundary, reconstruction (PCA, ICA, NMF), clusters. Each has a blind spot (dense floods for LOF, correlations for axis cuts); no detector wins everywhere.
- The covariance matters: Mahalanobis sees broken relations that per-feature z-scores miss.
- Report AUPRC, per-category recall and the spread over splits; deduplicate first.
- Classifiers catch what they have seen; one-class detectors are for the rest. Use both.

Why d_M^2 follows a χ_d^2 distribution

- Let $\mathbf{x} \sim \mathcal{N}(\mu, C)$ and $C = LL^\top$ (Cholesky). Define $\mathbf{u} = L^{-1}(\mathbf{x} - \mu)$.
- $\mathrm{Cov}(\mathbf{u}) = L^{-1}CL^{-\top} = L^{-1}LL^\top L^{-\top} = I$: the u_j are independent standard normals.
- $d_M^2 = (\mathbf{x}-\mu)^\top (LL^\top)^{-1}(\mathbf{x}-\mu) = \mathbf{u}^\top\mathbf{u} = \sum_{j=1}^{d} u_j^2$.
- A sum of d squared independent standard normals is χ_d^2 by definition. For $d = 2$: $P(\chi_2^2 > c) = e^{-c/2}$, so $P(d_M^2 > 20) = e^{-10} = 4.5 \times 10^{-5}$ (point B).

LOF in full

- k-distance of $\mathbf{o}$: distance to its k-th neighbour.
  Reachability distance:
  $\mathrm{rd}_k(\mathbf{x}, \mathbf{o}) = \max\{k\text{-dist}(\mathbf{o}),\ d(\mathbf{x}, \mathbf{o})\}$ (smooths small distances).
- Local reachability density:
  $\mathrm{lrd}(\mathbf{x}) = \left(\frac{1}{k} \sum_{\mathbf{o} \in N_k(\mathbf{x})} \mathrm{rd}_k(\mathbf{x}, \mathbf{o}) \right)^{-1}$.
- $\mathrm{LOF}_k(\mathbf{x})$ = mean of $\mathrm{lrd}(\mathbf{o}) / \mathrm{lrd}(\mathbf{x})$ over the neighbours: a ratio, so it adapts to regions of different density (its strength) and returns 1 inside any dense cluster, malicious or not (its weakness).

Isolation Forest: where $c(n)$ comes from

- An isolation tree is a random binary search tree; isolating a point equals an **unsuccessful search** in a BST of n keys.
- Its mean path length is $c(n) = 2H(n-1) - 2(n-1)/n$ with $H(i) = \sum_{m=1}^{i} 1/m \approx \ln i + 0.5772$ (Euler's constant).
- Normalising by $c(n)$ makes scores comparable across subsample sizes: $E[h] \to 0 \Rightarrow s \to 1$; $E[h] = c(n) \Rightarrow s = 0.5$; $E[h] \gg c(n) \Rightarrow s \to 0$.

References

Axelsson, Stefan. 2000. “The Base-Rate Fallacy and the Difficulty of Intrusion Detection.” ACM Transactions on Information and System Security 3 (3).

Breunig, Markus M., Hans-Peter Kriegel, Raymond T. Ng, and Jörg Sander. 2000. “LOF: Identifying Density-Based Local Outliers.” ACM SIGMOD International Conference on Management of Data.

Chandola, Varun, Arindam Banerjee, and Vipin Kumar. 2009. “Anomaly Detection: A Survey.” ACM Computing Surveys 41 (3).

Ester, Martin, Hans-Peter Kriegel, Jörg Sander, and Xiaowei Xu. 1996. “A Density-Based Algorithm for Discovering Clusters in Large Spatial Databases with Noise.” International Conference on Knowledge Discovery and Data Mining (KDD).

Han, Songqiao, Xiyang Hu, Hailiang Huang, Minqi Jiang, and Yue Zhao. 2022. “ADBench: Anomaly Detection Benchmark.” Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks.

Hyvärinen, Aapo, and Erkki Oja. 2000. “Independent Component Analysis: Algorithms and Applications.” Neural Networks 13 (4–5): 411–30. https://doi.org/10.1016/S0893-6080(00)00026-5.

Ledoit, Olivier, and Michael Wolf. 2004. “A Well-Conditioned Estimator for Large-Dimensional Covariance Matrices.” Journal of Multivariate Analysis 88 (2).

Lee, Daniel D., and H. Sebastian Seung. 1999. “Learning the Parts of Objects by Non-Negative Matrix Factorization.” Nature 401 (6755): 788–91. https://doi.org/10.1038/44565.

Liu, Fei Tony, Kai Ming Ting, and Zhi-Hua Zhou. 2008. “Isolation Forest.” IEEE International Conference on Data Mining (ICDM).

Rousseeuw, Peter J., and Katrien Van Driessen. 1999. “A Fast Algorithm for the Minimum Covariance Determinant Estimator.” Technometrics 41 (3).

Ruff, Lukas, Robert A. Vandermeulen, Nico Görnitz, et al. 2020. “Deep Semi-Supervised Anomaly Detection.” International Conference on Learning Representations (ICLR).

Schölkopf, Bernhard, John C. Platt, John Shawe-Taylor, Alex J. Smola, and Robert C. Williamson. 2001. “Estimating the Support of a High-Dimensional Distribution.” Neural Computation 13 (7).

Sommer, Robin, and Vern Paxson. 2010. “Outside the Closed World: On Using Machine Learning for Network Intrusion Detection.” IEEE Symposium on Security and Privacy.

Tavallaee, Mahbod, Ebrahim Bagheri, Wei Lu, and Ali A. Ghorbani. 2009. “A Detailed Analysis of the KDD CUP 99 Data Set.” IEEE Symposium on Computational Intelligence for Security and Defense Applications (CISDA).